

SOFTWARE REQUIREMENTS SPECIFICATION -- CONFIDENTIAL

Human Resource Management System

Flask + DuckDB - HRMS Portal

A comprehensive, shift-aware, RBAC-driven HR platform for the modern enterprise

VERSION	1.0 -- Baseline (Approved for Development)
DATE	13 May 2026 (IST)
AUTHOR	HRMS Engineering - Auto-generated via codebase analysis
REPOSITORY	github.com/ShubhamvijayJawalkar/CWLiveweb - branch: main
REFERENCE	OrangeHRM CE 5.x - IceHRM 34 - Sentrifugo 3.2 - Odoo HR - IEEE 830-1998
STATUS	APPROVED FOR DEVELOPMENT / BASELINE

34+ TABLES	16 BLUEPRINTS	85+ ENDPOINTS	21 PERM MODULES	6 ROLES	258 TESTS
---------------	------------------	------------------	--------------------	------------	--------------

DISTRIBUTION & CLASSIFICATION

Prepared for: Product Owner, Engineering, QA, DevOps, HR Stakeholders, Auditors

This SRS was reverse-engineered from the live codebase (`hrms/__init__.py`, `hrms/schema.py`, 16 blueprints, 35 templates) and cross-validated against leading open-source HRMS to ensure workflow completeness. It is the single source of truth for implementation, QA traceability, and audit.

IEEE 830-1998 - OWASP ASVS 4.0 - ISO 25010

Table of Contents

1. Introduction -- Purpose, Scope, Definitions, References, Overview	5
2. Overall Description -- Perspective, Functions, Users, Env, Constraints	6
3. System Architecture -- Logical, DB, Security, Deployment	8
4. Stakeholders & User Classes -- Primary / Secondary	9
5. Functional Requirements -- FR-AUTH ... FR-AST (21 groups, 100+ IDs)	10
6. Workflow Specifications -- 12 BPMN-style lifecycles incl. 5-step onboarding	22
7. Data Model / ERD -- 34+ tables, FK graph, key columns	27
8. API Specification -- >85 endpoints + JSON examples	30
9. UI / UX Requirements -- 35 templates, design system, a11y	36
10. Non-Functional Requirements -- Perf, Availability, Security, Backup	38
11. Security Requirements -- 10 controls incl. gap remediation	39
12. Reporting & Analytics -- Reports + 5 analytics endpoints	40
13. Deployment & DevOps -- Docker, Render, Scheduler caveat	41
14. Traceability Matrix -- FR → Code → Template → Test	42
15. Glossary -- Terms & abbreviations	43
16. Appendices -- Seed, Matrix, Benchmark, Roadmap, History	44

REVISION HISTORY

Version	Date	Author	Change
0.1	2026-05-13	HRMS Eng. (agent)	Initial generation via codebase explore + manual read
1.0	2026-05-13	HRMS Eng.	Baseline -- Approved for Development

HOW TO READ THIS DOCUMENT

Each FR uses form **FR-<MOD>-<NNN>** with priority **M/H/L** and code pointer (**file:line**). Workflows in §6 give state machines & decision tables; §7 gives physical schema; §8 lists every endpoint with auth. Executable trace: **README tests (258)** must be run separately via **DB_FILE** env to avoid 403 flakes (AGENTS.md).

REFERENCE BENCHMARKS

OrangeHRM CE 5.x Leave, attendance, PIM, recruitment	Sentrifugo 3.2 Onboarding, offboarding, assets, analytics	IceHRM 34 Payroll, expenses, helpdesk, projects	Odoo HR Integrated ERP baseline
--	---	---	---

Version: 1.0**Date:** 2026-05-13**Author:** HRMS Engineering (auto-generated via codebase analysis)**Status:** Approved for Development / Baseline**Repository:** C:\Users\CW230503\Desktop\HRMS (Flask, DuckDB, Jinja2, APScheduler)**Reference Systems:** OrangeHRM CE 5.x, IceHrm 34, Sentrifugo 3.2, Odoo HR -- studied for workflow completeness

1. Introduction

1.1 Purpose

This SRS describes requirements for the **HRMS Portal** -- a web-based Human Resource Management System providing employee lifecycle management, time & attendance, break governance, leave/regularization, payroll, expenses, helpdesk, assets, documents, onboarding/offboarding, performance, recruitment (ATS), holidays, notifications, reports and audit.

Target readers: product owners, developers, QA, DevOps, HR stakeholders, and auditors. The document is derived from the existing codebase (`hrms/__init__.py:77`, `hrms/schema.py:17`, all 16 Blueprints) and cross-checked against leading open-source HRMS (see Sec. 1.5).

1.2 Scope

The system is **in-scope**: - Web portal (responsive, Bootstrap 5) + JSON APIs + Swagger (`/docs/`, `/apispec.json` -- `hrms/__init__.py:92`). - Authentication & RBAC with per-module permission overrides (`hrms/helpers.py:72` -- 21 modules). - Shift-aware attendance (IST, `Asia/Kolkata`), break quotas, lunch-approval gate. - Leave balances, holidays (National/Optional + opt-in), regularization. - Payroll runs, salary structures, payslip PDF, TDS, bank file. - ATS: jobs -> candidates -> interviews -> offers -> hire -> onboarding. - Off-boarding 5-step workflow, exit interviews. - Notifications (in-app + email with per-category preferences), audit log. - Reports/exports (Excel, CSV, iCal, PDF), analytics dashboards.

Out-of-scope: mobile native apps, biometric hardware integration, third-party SSO (SAML/OIDC), external payroll gateways -- listed as future (Sec. 16.4).

1.3 Definitions & Abbreviations

Term	Meaning
HRMS	Human Resource Management System
ATS	Applicant Tracking System
RBAC	Role-Based Access Control
IST	Indian Standard Time (<code>ZoneInfo('Asia/Kolkata')</code> , <code>hrms/helpers.py:17</code>)
SLA	Service Level Agreement (tickets)
TDS	Tax Deducted at Source (Indian slabs)
FIFO / LIFO	Login first / Logout last -- <code>shift_hours = last_logout - first_login</code> (<code>hrms/attendance.py:250</code>)

1.4 References

- Codebase: `app.py:14`, `hrms/schema.py`, `hrms/helpers.py:514`, `AGENTS.md`
- Open-source benchmarks: **OrangeHRM** (leave, attendance, PIM, recruitment), **Sentrifugo** (onboarding/offboarding, analytics, assets), **IceHRM** (payroll, expenses, helpdesk, projects) -- used to validate gap coverage (e.g., Lunch approval mirroring OrangeHRM Leave approval chain, Sentrifugo-style onboarding checklist expansion, IceHRM expense categories).
- Standards: IEEE 830-1998 SRS, OWASP ASVS 4.0, ISO 25010

1.5 Overview

Remainder: Sec. 2 product perspective, Sec. 3 architecture, Sec. 5 functional FRs (FR-AUTH ... FR-AUDIT), Sec. 6 end-to-end workflows with BPMN-style, Sec. 7 data model (34 tables), Sec. 8 API catalog (>85 endpoints), Sec. 9 UI, Sec. 10 NFRs, Sec. 11 security.

2. Overall Description

2.1 Product Perspective

HRMS is a **monolithic Flask application** using **DuckDB file DB** (`hrms.duckdb`, `hrms/db.py:1 --_PersistentConnection`), deployable via Docker/Render (`Dockerfile`, `render.yaml`). It supersedes spreadsheets and disjoint HR tools. It interfaces: - **Users** via browser (role-gated nav: `templates/_navbar.html`) - **Email** via SMTP (`helpers.send_email`, `SMTP_HOST` env) - **Scheduler** (`APScheduler`, `hrms/__init__.py:204`) for orphan-break cleanup hourly & quarterly review cycle creation.

```
[ Browser ] --HTTPS--> [ Flask + Jinja2 + Blueprints ] --SQL--> [ DuckDB ]
                        |-> APScheduler (cleanup, review_cycle)
                        |-> SMTP / S3-like uploads (local `uploads/`)
                        |-> Swagger / AuditLog
```

2.2 Product Functions (Summary)

- Identity & Access (6 roles + 21 permission modules + overrides)
- Time: sessions (login hours), breaks (Tea 15m / Lunch 60m / Personal 30m), calendar, shift (Fixed / 24x7, `shift_start/shift_end`)
- Absence: leave (Casual 12 / Sick 10 / Annual 20 default), holidays, regularization
- Compensation: payroll monthly runs, structures, PF/ESI/PT, TDS slabs, iCal
- Lifecycle: onboarding 5-step, offboarding 5-step, documents, dependents, assets
- Talent: goals/reviews/360°, ATS pipeline (6 stages)
- Service: tickets (HR/IT queues, subcategories), expenses (6 categories), notifications
- Oversight: admin dashboard (live stats), reports, analytics, audit

2.3 User Classes & Characteristics

Role	Access	Persona
Super Admin (EMP001)	All modules, purge, payroll rates, user import	IT/HR lead, owns system
Admin	All modules (perm default = all, <code>helpers.py:80</code>), no purge self	Ops manager
HR (role HR or dept HR, <code>helpers._is_hr</code>)	users, leaves, regularization, breaks, holidays, expenses, onboarding/offboarding, reports/audit/analytics/candidates	HR specialist (limited purge)
IT	tickets, assets, documents, reports	Helpdesk + asset admin
Team Leader	leaves, regularization, reports, performance	Approves direct reports
Employee	Self-data: own breaks/leaves/profile/salary slip/expenses/tickets/goals/documents	Individual contributor

Per-user overrides via `user_permissions` (`helpers.user_has_permission`) can grant/revoke any of 21 modules even for Admin (explicit `allowed=0` denies).

2.4 Operating Environment

- Python 3.10+, Flask 3, DuckDB 1.0, bcrypt, Flask-Limiter, APScheduler, reportlab/openpyxl, gunicorn, Docker
- Env vars: `SECRET_KEY`, `FLASK_ENV`, `PORT`, `DB_FILE`, `UPLOAD_FOLDER`, `SMTP_*`, `SENTRY_DSN` (`AGENTS.md`, `.env.example`)
- Browsers: Evergreen Chrome/Firefox/Safari/Edge; mobile responsive.

2.5 Design & Implementation Constraints

- **DB**: single DuckDB file -- concurrent writes limited; `_PersistentConnection` avoids close; not for high-concurrency clusters (future: Postgres).
- **Uploads**: 10 MiB cap, 11 extensions (`helpers.ALLOWED_EXTENSIONS`), local FS (`uploads/`).
- **Clock**: IST everywhere (`helpers.now_ist` strips TZ for storage, `iso_ist` adds +05:30 on read).

- **Passwords:** 6 char minimum (auth & users), bcrypt.
- **Pagination:** max 200 (users.py).

2.6 Assumptions & Dependencies

- Users provide valid HH:MM shift or 24x7; night shift (end < start) rolls to next day (helpers._get_shift_end_dt).
- SMTP optional -- disabled logs only.
- Migrations idempotent (15 migrations migrations.py:84).
- Session 8h, HttpOnly/Lax/Secure(prod) (__init__.py:82).

3. System Architecture

3.1 Logical Architecture

```
app.py (create_app)                hrms/schema.py (init_db + seed)
|-> extensions (limiter, scheduler)
|-> Blueprints (16):
|  auth      (login, sessions, pwd reset, csrf)      `hrms/auth.py:1`
|  users     (CRUD, bulk, import, perms, profile)    `hrms/users.py:1`
|  attendance (breaks, shift, calendar, live)        `hrms/attendance.py:1`
|  leaves    (requests, balance, grants)            `hrms/leaves.py:1`
|  payroll   (structures, runs, payslip, TDS)        `hrms/payroll.py:1`
|  expenses  (categories, claims)                   `hrms/expenses.py:1`
|  tickets   (queues, assignment)                   `hrms/tickets.py:1`
|  documents (upload/download)                       `hrms/documents.py:1`
|  onboarding (5-step, checklist)                    `hrms/onboarding.py:1`
|  offboarding (5-step, exit interviews)              `hrms/offboarding.py:1`
|  performance (goals, reviews, 360)                `hrms/performance.py:1`
|  holidays  (calendar, opt-in, iCal)                `hrms/holidays.py:1`
|  ats       (jobs, candidates, interviews, offers) `hrms/ats.py:1`
|  analytics  (headcount, attrition...)              `hrms/analytics.py:1`
|  reports    (summary, exports)                     `hrms/reports.py:1`
|  audit      (log, modules)                         `hrms/audit.py:1`
|  notifications (prefs, send)                      `hrms/notifications.py:1`
|  assets     (issue/return)                         `hrms/assets.py:1`
|-> helpers / decorators / db
```

No microservices -- single deployable. Horizontal scaling requires DB swap.

3.2 Database Tier

- File DB_FILE (default hrms.duckdb), migrations table schema_migrations.
- Thread-local connection.
- Seed: 6 users, 3 break types (Tea 15/Lunch 60/Personal 30), 6 expense cats, 5 holidays/year, 3 leave balances/user, sample rows for all modules (see schema.py:633+).

3.3 Security Architecture

- Bcrypt, session cookies, CSRF token endpoint (/api/csrf-token), rate-limiter memory, security headers (__init__.py:191).

3.4 Deployment View

- Dockerfile + gunicorn; render.yaml one-click; .secret_key persistence; APScheduler in-process (avoid duplicate in multi-worker -- TODO migrate to external cron).

4. Stakeholders & User Classes

(See Sec. 2.3 plus) - **Primary stakeholders:** HR, Finance/Payroll, IT, Hiring managers, Employees, Auditors. - **Secondary:** Vendor IT, Management for analytics.

5. Functional Requirements

Format FR-<MOD>-<NNN>, priority M/H/L (Must/High/Low), linked to code.

FR-AUTH: Authentication & Session (hrms/auth.py:1)

ID	Requirement	Priority	Verification	Source
FR-AUTH-01	Login with emp_id (case-insensitive, trimmed, upper) + password via POST /login. Rate 20/min. Errors: 400 missing, 401 invalid, 403 blocked/archived/login-disabled. On success create user_sessions with session_date = shift_date(dt=login_time) (helpers._get_shift_date_for_dt) and session.{emp_id,name,role,department,session_id}; audit LOGIN.	M	tests/test_app.py login, auth.py:28	AGENTS.md
FR-AUTH-02	Logout GET /logout closes active session: total_hours=(logout-login)/3600, audits LOGOUT, clears session.	M	--	--
FR-AUTH-03	Root / redirects to /dashboard if authed else /login.	M	--	--
FR-AUTH-04	Dashboard GET /dashboard: Admin/HR -> admin_dashboard.html with stats=_compute_dashboard_stats(), else user_dashboard.html with shift_summary. Unauth -> 302 login.	M	@login_required	--
FR-AUTH-05	Forgot password POST /api/forgot-password (5/min): requires emp_id+email exact match; generate token_urlsafe(32) exp 1h in password_reset_tokens; email link {host_url}reset-password?token=; 404 if mismatch.	H	--	--
FR-AUTH-06	Reset POST /api/reset-password (5/min): token+new_password len≥6, token valid used=0 && expires>now, mark used, bcrypt update, audit. Errors 400.	H	--	--
FR-AUTH-07	CSRF GET /api/csrf-token auth required, returns token_hex(32) stored in session.	H	--	--
FR-AUTH-08	Credentials GET /api/credentials admin only, lists emp_id,name,role,department.	L	--	--
FR-AUTH-09	Session conf: 8h, HttpOnly, Lax, Secure in prod, ProxyFix.	M	__init__.py:81	--
FR-AUTH-10	Scheduler hourly cleanup: delete expired tokens; orphan Active breaks >12h -> Orphaned, duration 0, end=now (__init__.py:63).	H	--	--

FR-USR: User Management (hrms/users.py:1)

ID	Requirement	Priority
FR-USR-01	List GET <code>/api/users</code> (perm users): pagination <code>page/per_page</code> (max200), filters search(ILIKE <code>emp_id/name/email</code>), <code>role</code> , <code>status</code> , <code>department</code> , <code>active?</code> , sort <code>sort_by</code> IN { <code>emp_id</code> , <code>name</code> , <code>email</code> , <code>role</code> , <code>department</code> , <code>status</code> , <code>create_d_at</code> } else fallback, <code>sort_dir</code> . Returns data + total <code>/page/per_page/{last_login,onboarding state}</code> .	M
FR-USR-02	Create POST <code>/api/users</code> (perm users): required <code>emp_id</code> (EMP\d+ regex), <code>name</code> , <code>email</code> (@), <code>role</code> in ROLES, <code>department</code> ; dup <code>emp_id</code> 409, dup email case-insensitive 409, default <code>Active/allow_login=1/allow_breaks=1</code> , seed <code>leave_balance</code> (12/10/20), send welcome with 24h reset token.	M
FR-USR-03	Get/Update detail GET/PUT <code>/api/users/<emp_id></code> (perm users): 29 updatable cols incl for <code>shift_start</code> <code>/shift_end/designation/manager_emp_id/...</code> , email dup 409, role check, 400 no fields.	M
FR-USR-04	Block/Unblock POST <code>/api/users/<emp_id>/block unblock -> Blocked/Active</code> , audit.	H
FR-USR-05	Archive DELETE <code>/api/users/<emp_id> -> Archived + archived_at=now</code> ; self-archive 400. Restore POST <code>.../restore -> Active</code> .	H
FR-USR-06	Purge POST <code>/api/users/<emp_id>/purge</code> (admin only): cascades across 24+ tables (sessions/breaks/leaves/approvals/audit/notifications/...tickets/comments/documents/dependents/interviews/prefs/permissions), self-purge blocked, 500 on failure.	H
FR-USR-07	Bulk POST <code>/api/users/bulk</code> (perm users): { <code>action:block unblock archive</code> , <code>emp_ids[]</code> } self-excluded.	H
FR-USR-08	Meta GET <code>/api/users/meta</code> , Export GET <code>/api/users/export</code> (CSV same filters), Sessions GET <code>/api/users/<id>/sessions</code> last50.	L
FR-USR-09	Permissions GET/PUT <code>/api/users/<id>/permissions</code> (perm users): list <code>get_user_permissions</code> ; PUT { <code>permissions:{module:bool}</code> } delete+insert, audit.	H
FR-USR-10	Import POST <code>/api/users/import</code> & <code>/api/v1/users/import</code> (perm users): multipart CSV via pandas, required <code>emp_id</code> , <code>name</code> , <code>email</code> , per-row validate regex/role/dup skip, insert+balance, returns { <code>imported</code> , <code>skipped</code> , <code>errors[:50]</code> } 201. Page GET <code>/admin/import-users</code> (hr_or_admin).	H
FR-USR-11	Dependents GET/POST <code>/api/dependents</code> (+v1) auth only: own list/create (<code>name+relationship</code> required), DELETE <code>/api/dependents/<id></code> ownership (<code>emp_id=me</code>).	M
FR-USR-12	Employee docs POST <code>/api/employee-documents</code> (auth): { <code>doc_type</code> , <code>file_name</code> } -> documents { <code>Personal</code> , <code>doc_type</code> }.	L
FR-USR-13	Profile: page <code>/profile</code> , API GET <code>/api/profile</code> 23+ fields + 14 extended, PUT <code>/api/profile</code> updates 26 cols, email dup 409, sync <code>session.name</code> .	M
FR-USR-14	Change password POST <code>/api/change-password</code> (auth): { <code>current</code> , <code>new</code> } len≥6, check current 400.	M
FR-USR-15	Navbar role-gate: Users/OrgChart/Holidays admin-only; Modules admin/HR; Salary/Import admin-only (per AGENTS.md).	M

FR-ATT: Attendance / Breaks / Shift / Calendar (hrms/attendance.py:1, hrms/helpers.py:265)

ID	Requirement	Priority
FR-ATT-01	Break types: Tea 15m, Lunch 60m, Personal 30m (break_types, schema.py:71). Lunch requires_approval=True.	M
FR-ATT-02	Start POST /api/start-break (auth): {break_type} required; 403 if allow_breaks=0; validate type 400; if daily_limit then SUM(Completed where start>=shift_start_dt(emp)) >= limit =>400; Lunch requires break_approvals {emp,Lunch, shift_date, status in Pending/Approved} else 403; auto-end existing Active break (Completed) before inserting new Active, break_date=shift_date(now); 201.	M
FR-ATT-03	End POST /api/end-break/<id> (auth): owns break else 404; duration=(end-start)/60, set Completed, audit. Frontend endBreak() self-heals if localStorage.activeBreakId missing (ref AGENTS).	M
FR-ATT-04	List GET /api/user-breaks (auth): shift_start_dt scoped, WHERE (status Active OR start>=shift_start) ORDER DESC (union active any date + today's Completed) (attendance.py:91).	M
FR-ATT-05	Break approvals GET/POST /api/break-approvals: GET all if admin else own; POST only Lunch, duplicate pending per shift_date =>409, insert Pending.	H
FR-ATT-06	Approve/Reject POST /api/break-approvals/<id>/approve reject (auth internal): allow if current==manager_emp_id OR is_admin OR dept HR else 403; update status + audit + notify.	H
FR-ATT-07	Types GET /api/break-types (auth): per type {used_minutes (Completed since shift_start), requires_approval, approval_status (latest for shift_date)}.	L
FR-ATT-08	Login hours GET /api/login-hours?date=YYYY-MM-DD (auth): target defaults current shift_date; sessions where session_date=target, return login/logout/total.	M
FR-ATT-09	Shift summary GET /api/user/shift-summary?date= (auth): shift_start_dt(target_date) + shift_end_dt (night-roll), total_session_hours, total_break_minutes, first_login, last_logout, shift_hours=(last_logout-first_login or now-first) , productive=shift-break/60, efficiency=productive/shift*100. (_compute_shift_summary).	H
FR-ATT-10	Change AGENTS: login hours = last logout - first login (not sum).	M
FR-ATT-11	Calendar GET /api/user/calendar?month&year (auth): range first - last day month; fetch sessions/breaks/leaves(expands day-by-day)/holidays + shift cols; returns 4 maps.	H
FR-ATT-12	Live monitoring GET /api/live-monitoring (admin): Active breaks where start>=earliest_shift_of_employees.	L
FR-ATT-13	Break summary GET /api/break-summary (admin): per-employee active/completed counts + total_break_minutes via LEFT JOIN breaks since earliest shift.	L
FR-ATT-14	Disposed breaks GET /api/disposed-breaks (admin): Completed where end>=now-1h && break_date=current_shift_date.	L
FR-ATT-15	Dashboard stats GET /api/dashboard-stats (admin): total Employees, logged_in_today (distinct session_date per shift_date groups), on_break, blocked, pending_leaves (_compute_dashboard_stats). Fix JSON key online -> online, etc (AGENTS).	M

ID	Requirement	Priority
FR-ATT-16	Admin breaks GET <code>/api/admin/breaks</code> (admin): {active (Active+shift_date), disposed (Completed last 20), summary GROUP BY type}. Dispose POST <code>/api/admin/dispose-break/<id></code> (admin): end any Active $\Rightarrow$ Completed, audit.	H
FR-ATT-17	Shift columns shift_start/shift_end in user CRUD forms & table, selector Fixed/24 $\times$ 7 (AGENTS), helpers._get_shift_start_dt/_end_dt/_get_shift_date_for_dt. Night shift supported.	M

FR-REG: Regularization (hrms/attendance.py:405)

ID	Requirement
FR-REG-01	List GET <code>/api/regularization?(pending_my_approval,status,month)</code> (auth): pending_my_approval=true $\Rightarrow$ manager_emp_id=me && Pending; else admin sees filtered with counts {pending/approved/rejected/cancelled/total}, employee sees own (+ month filter).
FR-REG-02	Create POST <code>/api/regularization</code> (auth): {date,reason} required, future date 400, duplicate Pending per date 409, inserts Pending.
FR-REG-03	Approve/Reject POST <code>/api/regularization/<id>/approve reject</code> (auth manager/HR): allow current==manager OR admin/HR else 403; not-pending 404/400; update + audit + notify; cancel POST <code>/api/.../cancel</code> (own or admin) only Pending else 400.
FR-REG-04	Export GET <code>/api/regularization/export?month&status</code> (admin): Excel Regularization. Page <code>/regularization</code> (auth) renders with is_admin/is_manager.

Similar v1 prefix aliases exist.

FR-LEA: Leaves (hrms/leaves.py:1)

ID	Requirement
FR-LEA-01	Pages: <code>/leaves</code> (auth) + <code>/admin/leaves</code> (hr_or_admin). List GET <code>/api/leaves?(status,month,year,pending_my_approval)</code> (auth): 3-branches -- pending_my_approval $\Rightarrow$ manager_emp_id=me && Pending, admin $\Rightarrow$ filters year/month/status, else own filtered.
FR-LEA-02	Create POST <code>/api/leaves</code> : {leave_type,start_date,end_date,reason}; sd/ed via parse_date, swap if ed<sd; balance check against leave_balance{year=now}: requested=(ed-sd+1) > remaining $\Rightarrow$ 400; overlap check Pending/Approved && start<=ed && end>=sd $\Rightarrow$ 409; insert Pending with year=sd.year; audit+notify.
FR-LEA-03	Export GET <code>/api/leaves/export?month&year&status</code> (admin): Excel Leaves.
FR-LEA-04	Approve POST <code>/api/leaves/<id>/approve</code> (auth manager/HR): routing current==manager OR admin/HR else 403; pending check; days=(end-start+1)-holidays BETWEEN; set Approved + leave_balance.used_days+=days + audit+notify.
FR-LEA-05	Reject similarly sets Rejected. Cancel POST <code>/api/leaves/<id>/cancel</code> : own or admin only, only Pending else 400.
FR-LEA-06	Balance GET <code>/api/leave-balance</code> (auth): year=now, rows for Casual/Sick/Annual (12/10/20) + custom types, {total,used,remaining}.
FR-LEA-07	Grants GET <code>/api/leave-grants?(month,year,leave_type,emp_id)</code> (hr_or_admin) list. POST <code>/api/leave-grants</code> (hr_or_admin): {leave_type in Casual/Sick/Annual, days 1-365 int, month1-12, year2000-2100, emp_ids[]} dedup, validate existing users, per emp upsert balance +total+=days, insert grant row, notify, audit LEAVE_GRANT.

FR-PAY: Payroll (hrms/payroll.py:1, hrms/helpers.py:362)

ID	Requirement
FR-PAY-01	Pages: /admin/payroll, /admin/settings/payroll-rates (admin), /admin/salary-structures (hr/admin).
FR-PAY-02	Salary structures GET/POST /api/salary-structures (hr/admin): GET list; POST {emp_id+basic required, hra/allowances/deductions, effective_from parsed else now} insert. Preview POST /api/salary-structures/preview: {basic,hra,allowances,deductions} -> calc_payroll_item_from_rates + calc_tds_from_rates(gross*12)/12 -> {gross,pf,esi,pt,other,tota_l_ded,net,annual_gross,annual_tds,monthly_tds}.
FR-PAY-03	Payroll rates GET/PUT /api/payroll-rates (admin): GET all; PUT {id,value,...} update + audit. Rates table drives dynamic PF/ESI/PT/TDS (helpers._get_rates).
FR-PAY-04	Payroll calc: gross=basic+hra+allowances; pf=min(gross*pf_rate,pf_max) default12%/1800; esi=gross*esi_rate if gross<=esi_max(21000) else0; pt=pt_amount if gross>pt_threshold(10000) else0; total_ded=deductions+pf+esi+pt; net=gross-total (calc_payroll_item*). TDS slabs India: 0-3L 0%,3-6 5%,6-9 10%,9-12 15%,12-15 20%,>15 30% (calc_tds) else rates-driven.
FR-PAY-05	Runs GET/POST /api/payroll-runs (hr/admin): GET list; POST {month,year} duplicate 409; transaction: insert Draft + for each role Employee join latest salary_structures effective<=now, calc calc_payroll_item (hard-coded variant -- diverges from preview), insert items.
FR-PAY-06	Finalize POST /api/payroll-runs/<id>/finalize (hr/admin), Items GET /api/payroll-runs/<id>/items. Payslip JSON GET /api/payslip/<run>/<emp> (self/admin), My payslips GET /api/my-payslips (auth), PDF GET /api/payroll-runs/<id>/payslip-pdf/<emp> (self/admin, reportlab A4, sets payslip_generated=1, filename payslip_{emp}_{run}.pdf).
FR-PAY-07	Bank file GET /api/payroll-runs/<id>/bank-file (hr/admin): CSV Employee ID, Name, Net Salary, Account, IFSC; TDS report GET .../tds-report: {monthly_gross,annual_gross,tds} per item via calc_tds.
FR-PAY-08	Review cycle progress GET /api/review-cycle-progress (auth): Qn=(month-1)//3+1, totals per period; scheduler open_review_cycle cron quarterly 1st 02:00 creates Draft reviews for Active Employees, reviewer=first Admin else first employee.

FR-EXP: Expenses (hrms/expenses.py:1)

ID	Requirement
FR-EXP-01	Pages /admin/expenses (hr/admin), /expenses (auth) with is_manager flag; categories GET /api/expense-categories (auth) list 6 default.
FR-EXP-02	List/Create GET/POST /api/expenses?(pending_my_approval) (auth): pending_my_approval => manager pending; admin sees all else own; POST {cat_id,amount} required (note emp_id override from body allowed -- treat as legacy; enforce session). Insert Pending, cat validation omitted intentionally.
FR-EXP-03	Status PUT /api/expenses/<id>/status (auth manager/HR): {status in Pending/Approved/Rejected/Paid} 400; for Approved/Rejected require manager==current OR admin/HR else 403; Paid currently bypasses manager check (allow any logged -- capture as NFR gap to fix). Audit+notify.

FR-TKT: Tickets / Helpdesk (hrms/tickets.py:1)

ID	Requirement
FR-TKT-01	Constants QUEUES=(HR, IT), HR subcats (Payroll, Attendance, Leave...), IT subcats (Hardware, Network...) (tickets.py). Page /admin/tickets (department_required('HR','IT'), queues allowed Admin both else own dept), /tickets auth.
FR-TKT-02	List/Create GET/POST /api/tickets?(queue) (auth): GET visibility via _visible_where(emp_id assigned_to category=dept); admin sees filtered only; POST requires subject + queue category must be HR/IT 400 + sub_category defaults Others if not in queue map; insert Open, priority Medium, assigned None; notify_department(queue, ...) to dept + Super Admin.
FR-TKT-03	Detail GET /api/tickets/<id> (auth): visible if is_admin OR emp_id==me OR dept==category OR assigned_to==me else 403 (404 if missing). Comment POST /api/tickets/<id>/comment (auth): inserts + updated_at.
FR-TKT-04	Status PUT /api/tickets/<id>/status (auth): {status in Open/In Progress/Resolved/Closed} 400; resolved_at=now if Resolved. Assign PUT /api/tickets/<id>/assign (admin): {assigned_to} + audit.

FR-DOC: Documents (hrms/documents.py:1)

ID	Requirement
FR-DOC-01	Pages /admin/documents (hr/admin), /documents (auth). List GET /api/documents?(context) (auth): own unless admin/hr sees all.
FR-DOC-02	Upload POST /api/upload (+v1) (auth): multipart file required, validate_upload (11 ext, 10MiB) 400, emp_id session, category, context General, saved as {ts}_{original} in UPLOAD_FOLDER, file_size, insert documents (file_path=filename), audit.
FR-DOC-03	Download GET /api/documents/<id>/download (auth self/admin else 403, 404 if no file). Delete DELETE /api/documents/<id> (auth) -- currently any auth (gap: should be owner/admin, note as remediation). Audit. Migration 007 unified context General/Personal/Onboarding.

FR-ONB: Onboarding (hrms/onboarding.py:1, helpers.ONBOARDING_DOC_TYPES)

ID	Requirement
FR-ONB-01	Workflow 5 steps: 1 Document Upload -> 2 Document Validation (HR) -> 3 System Allocation -> 4 Desk & ID Card -> 5 Team Introduction (onboarding_workflow {current_step 1-5, step_1..5_status Pending/InProgress/Completed, intro_completed_by}). Doc types: ID Proof, Address Proof, Photo, Previous Organisation Documents, Qualification Documents.
FR-ONB-02	Page /onboarding (auth, flags is_admin, is_hr). Tasks GET/POST /api/onboarding-tasks?(status,month) (GET perm varies; POST any auth): POST {emp_id, task_name} inserts Pending; Complete POST /api/.../<tid>/complete (admin), Progress POST .../progress Pending -> InProgress (admin), Delete DELETE (admin), Export GET Excel.
FR-ONB-03	Checklist GET/POST /api/onboarding-checklist?(emp_id) (GET auth; POST admin): GET -- if target+admin/hr specific, else admin/hr sees all grouped {progress{uploaded,approved,total}, workflow map}, else own; POST {emp_id} 403 if non-admin, 409 if exists, creates 5 rows Pending + workflow current_step=1, step1 InProgress + users.status Onboarding + audit.
FR-ONB-04	Checklist upload POST /api/onboarding-checklist/<cid>/upload (owner/admin/HR 403): multipart + validate, size Photo 1MB else 250KB -> 413 else onboarding_{cid}_{ts}{ext}, update Uploaded. File GET .../file, Delete DELETE (admin), Review POST .../review (admin): {action Approved/Rejected+notes} Rejected requires notes 400; Rejected notify; Approved if all resolved && step2 notify. Initiate Setup POST /api/onboarding-initiate-setup (admin): all Approved else 400 {pending}, no existing IT System Setup/ID Card 409, creates 2 tasks due+7d.
FR-ONB-05	Proceed POST /api/onboarding-proceed (admin): {emp_id}, step-guarded: 2 -> 3 requires 5 Approved else 400 creates System Allocation due+7; 3 -> 4 requires System Allocation Completed, creates Desk & ID; 4 -> 5 sets InProgress. Submit POST .../submit (auth): step==1 else 400, ≥1 doc Uploaded/Approved else 400 ⇒ step1 Completed, step2 InProgress. Complete intro POST .../complete-intro (auth): step==5 else 400 ⇒ step5 Completed + if users.status Onboarding -> Active + notify.
FR-ONB-06	Status GET /api/onboarding-status (auth): own workflow else admin/hr active_onboarding list (users.status Onboarding join).

FR-OFF: Offboarding (hrms/offboarding.py:1)

ID	Requirement
FR-OFF-01	5 steps (labels Resignation -> Manager Clearance -> Asset Return -> Final Settlement -> Exit Interview & Access Revocation) via offboarding_workflow {step1..5_done BIT, completed}. Page /offboarding (auth).
FR-OFF-02	Tasks GET/POST /api/offboarding-tasks (auth GET scoped, POST any auth), Complete POST .../<tid>/complete (admin), Exit interviews GET/POST /api/exit-interviews (admin): {emp_id, reason, exit_date} required, list joins users.
FR-OFF-03	Workflow GET /api/offboarding-workflow (auth scoped), Proceed POST /api/offboarding-proceed (admin): {emp_id}, prev guard (previous done else 400), increments next stepX_done=1, notifies, step5 ⇒ completed=1 + users.status Inactive + notify_admins.

FR-PERF: Performance (hrms/performance.py:1)

ID	Requirement
FR-PERF-01	Pages /admin/goals (hr/admin), /admin/reviews -> redirect /dashboard, /goals (auth). Goals GET/POST /api/goals (auth GET admin all else own; POST {title required} inserts Active, emp_id session). Rate PUT /api/goals/<id>/rate (admin): rating 1-5 400 => Completed. Update PUT /api/goals/<id> (auth any) patches title/desc/date/weight/status.
FR-PERF-02	Reviews GET/POST /api/performance-reviews (hr/admin), Submit PUT /api/performance-reviews/<id>/submit (auth any -- no role check gap -- record). 360 feedback GET/POST /api/feedback-360 (auth: GET admin all else received; POST {emp_id+rating} inserts reviewer=session).

FR-HOL: Holidays (hrms/holidays.py:1, migration 10/14)

ID	Requirement
FR-HOL-01	Types National/Optional, locations (All default + user work_location). Page /holidays (auth can_manage=is_admin/hr), admin page /admin/holidays (perm holidays). List GET /api/holidays?(year, month, type, search, location, mine) (auth): year default now, search LIKE name/desc, location filter, mine or not-can_manage restricts to work_location vs All; returns {optin_count Approved, my_optin_status}.
FR-HOL-02	CRUD POST/PUT/DELETE /api/holidays... (perm holidays): POST {name+date required, type National/Optional 400, date parse 400, location All default, dup name+date 409}; PUT dup 409; DELETE cascade optins; audit + _notify_holiday_change (only Active allow_login + matching work_location). Copy POST /api/holidays/copy {from_year, to_year} distinct 400, per holiday Feb29 400, dup skip; Import POST /api/holidays/import {rows:[name,date,type,location,desc]} validates; Export GET CSV; iCal GET /api/holidays/calendar.ics?year&mine VCALENDAR all-day VC events.
FR-HOL-03	Opt-in POST /api/holidays/<id>/optin (auth: must be Optional else 400, existing 409 => Pending; Optout POST /api/holidays/<id>/optout delete own else 404. Opt-ins GET /api/holiday-optins?(status) (perm holidays) + approve POST .../<oid>/approve (perm holidays -> Approved + notify) + reject. Seed 5/year via migration_010.

FR-ATS: Recruitment / ATS (hrms/ats.py:1)

ID	Requirement
FR-ATS-01	Stages Applied, Screened, Interviewed, Offered, Hired, Rejected (ATS.STAGES). Pages /admin/jobs candidates offers pipeline (hr/admin). Pipeline GET /api/pipeline?(status,department) (hr/admin) aggregates per job stage_map GROUP BY status + converted counts (Pre-hire/Onboarding/Active via users.candidate_id join + onboarding_workflow steps) + employees list.
FR-ATS-02	Jobs GET/POST /api/jobs (admin), Close POST /api/jobs/<id>/close -> Closed. Candidates GET/POST /api/candidates?(job_id) (hr/admin), Status PUT /api/candidates/<id>/status (hr/admin) {status in STAGES} 400.
FR-ATS-03	Convert POST /api/candidates/<id>/convert (hr/admin): requires Hired else 400, creates user emp_id=gen_id str, role Employee, Pre-hire, allow_login0, optional department/designation/doj/manager, if Accepted offer salary>0 creates salary_structures basic50% hra20% allow20%, creates onboarding workflow 1+5 checklist Pending, audit, duplicate 400 if already.
FR-ATS-04	Interviews GET/POST /api/interviews?(candidate_id) (hr/admin), POST {candidate_id+scheduled_at (parses %Y-%m-%dT%H:%M:%S / %Y-%m-%d %H:%M:%S / %Y-%m-%d else null)}, Feedback PUT .../<id>/feedback (hr/admin) => Completed. Offers GET/POST /api/offers (hr/admin), POST {candidate_id+offered_salary} => Pending + candidate Offered; Accept POST .../<oid>/accept => Accepted+Hired+now, Reject POST .../reject => Rejected (idempotent even if missing).

FR-ANL: Analytics (hrms/analytics.py:1)

ID	Requirement
FR-ANL-01	Page /admin/analytics (hr/admin). Filters ?department, date_from, date_to. Endpoints (admin except perf hr/admin):
FR-ANL-02	Headcount GET /api/analytics/headcount: total + by_department (dept_where ALL ignored).
FR-ANL-03	Leave trends GET /api/analytics/leave-trends: months default 6 vs date range, GROUP BY strftime('%Y-%m', start_date), leave_type where Approved.
FR-ANL-04	Attrition risk GET /api/analytics/attrition-risk: heuristic score=leave_count*0.4 + reg_count*1.5 + early_break(<5min 1mo)*0.8 + (1-att_days/45)*3 where att distinct logins 3mo baseline 45 workdays; subqueries 3mo leaves Approved, pending regs, early breaks, ratings avg Submitted; top20 ORDER score.
FR-ANL-05	Expense summary GET /api/analytics/expense-summary: total Approved+Paid sum, by_category, pending_count. Perf summary GET /api/analytics/performance-summary (hr/admin): avg rating Submitted + by_dept group.

FR-RPT: Reports (hrms/reports.py:1)

ID	Requirement
FR-RPT-01	Pages /admin/reports (hr/admin, self_service False) + /reports (auth, self). List GET /api/reports (auth): _report_params() -> start/end (swap if reversed), department (if can_view_all else null), emp_id (if can else forced to self). _summary_query per user aggregates first_login MIN, last_logout MAX, sum total_hours, sum break mins, count breaks, count sessions, distinct present_days plus break/session detail queries. Helpers _count_working_days (Mon-Fri minus weekday holidays) + _compute_late_counts (MIN login vs shift_start >) -> metrics present_days/working_days, efficiency. Self-service restricts departments/employees to empty + rows to self (test-enforced).
FR-RPT-02	Export GET /api/reports/export (auth): 3-sheet Excel Summary/Break Details/Session Details via openpyxl (header #0F172A, auto-width, freeze, H:M:S). Dept summary GET /api/reports/department-summary (hr/admin): per-dept aggregated hours/breaks/productive/efficiency.

FR-AUD: Audit (hrms/audit.py:1)

ID	Requirement
FR-AUD-01	Page /admin/audit (hr/admin). Log GET /api/audit-log?limit200,offset,action(LIKE upper),module(prefix ACTION_ LIKE) (admin) ORDER created_at DESC + total. Modules GET /api/audit-modules (admin): distinct action.split('_')[0] 10 fallback. Audited actions: LOGIN, LOGOUT, BREAK_, LEAVE_, REGULARIZATION_, PAYROLL_, PROFILE_UPDATE, USER_PURGE, etc.

FR-NOT: Notifications (hrms/notifications.py:1, hrms/helpers.py:191)

ID	Requirement
FR-NOT-01	List GET /api/notifications (auth): last50 ORDER created_at DESC + unread count. Mark read POST /api/notifications/read (auth): deletes own rows (misnomer -- not mark but clear). Send POST /api/send-notification-email (admin): {to, subject, body, category Leaves} respects notification_preferences skip if email=0 else send_email; SMTP disabled => warning.
FR-NOT-02	Preferences GET/POST /api/notification-preferences (auth): GET fixed cats [Onboarding, Leaves, Expenses, Tickets, Payroll] defaults true; POST expects [{category, in_app, email}] list 400 else upsert. Insert via add_notification respects in_app/email prefs + category mapping Leaves/Expenses/Tickets/Onboarding/Payroll (_category_for_type). Notify helpers add_notification, notify_admins, notify_department(HR/IT) to dept+Super Admin.

FR-AST: Assets (hrms/assets.py:1)

ID	Requirement
FR-AST-01	Page /admin/assets (hr/admin). My assets GET /api/my-assets (auth) own; List/Create GET/POST /api/assets?(emp_id) (admin): GET join users; POST {emp_id+asset_type required, verify Active user else 400} inserts Issued, issued_date parse else now. Return POST /api/assets/<id>/return (admin): Returned, return_date=now. Seed 2 laptops/phones per EMP002.

6. Workflow Specifications

6.1 Authentication & Session Lifecycle

```
Employee -> POST /login {emp_id, password} --validate/bcrypt--> DB users
-> if allow_login=0 => 403 | Blocked/Archived => 403
-> insert user_sessions {session_id=gen_id, login_time=now_ist,
session_date=shift_date(login)}
-> session cookie (8h, HttpOnly, Lax)
-> audit LOGIN
-> 302 dashboard

Active session -> GET /logout -> find active by session_id or latest null logout
-> total_hours=(logout - login)/3600 update
-> audit LOGOUT -> clear cookie
```

6.2 Break & Lunch Approval Workflow

```
[State] None -> StartBreak -> Active -> EndBreak -> Completed
|
| -> Orphaned (12h timeout via scheduler)
|
| -> Admin Dispose -> Completed
```

Rules:

- Daily quota enforced on Completed since shift_start_dt(emp) (not calendar day).
- Auto-end: if Active exists, UPDATE before new insert (no 409).
- Lunch gate: requires break_approvals {Lunch, shift_date, Pending/Approved}.
- Approval chain: manager_emp_id is owner; fallback HR/Admin if no manager; is_admin OR dept==HR overrides.

Sequence (Lunch):

```
Employee --POST /api/break-approvals {Lunch}--> Pending
--notify manager/HR via notification--
Manager/HR --POST /approve --> Approved
Employee --POST /api/start-break Lunch --> checks approval exists --> Active
Employee --POST /api/end-break/<id> --> Completed + duration calc
```

Failure paths: 400 quota, 403 no approval, 409 duplicate pending, 404 break not owned.
Frontend resilience: if localStorage.activeBreakId missing, fetch /api/user-breaks to self-heal (AGENTS).

Break-approval decision table (approve/reject):

Target has manager	Actor is manager	Actor is HR/Admin	Result
Yes	Yes	*	Allow
Yes	No	Yes	Allow
Yes	No	No	403
No	*	Yes	Allow
No	*	No	403

6.3 Leave Lifecycle (mirrors OrangeHRM)

```
Employee --POST /api/leaves {type,start,end}--> Validate balance (remaining) --> Check
overlap (Pending/Approved) --> Pending
|
| --> notify manager
Manager/HR/Admin --POST /approve--> days=(end-start+1) - holidays BETWEEN --> balance.
used_days+=days --> Approved + notify
--POST /reject--> Rejected + notify
Employee/Admin --POST /cancel--> Only Pending + own|admin else 403 --> Cancelled
HR/Admin --POST /api/leave-grants {type,days,month,year,emp_ids} --> upsert
balance + grant rows + notify per emp
```

Leave balance is per-type per-year; holidays inside range are deducted (does not consume leave).

6.4 Regularization (Attendance Correction)

```
Employee POST /api/regularization {date,reason} --future 400, duplicate pending 409-->
Pending
Manager/HR POST /approve|reject (same matrix as leaves) --> Approved/Rejected + notify
Employee/Admin POST /cancel (only Pending, own|admin) --> Cancelled
Admin GET /api/regularization/export --> Excel
```

Identical approval routing: `manager_emp_id` or HR/Admin fallback.

6.5 Onboarding 5-Step (Sentrifugo-inspired exhaustive)

```
Start: HR creates checklist POST /api/onboarding-checklist {emp_id}
      -> 5 rows + workflow current_step=1 step1 InProgress + user status Onboarding

Step1 (Upload): Employee uploads docs POST ../upload (250KB except Photo 1MB) ->
Uploaded
      Submit POST ../submit: needs ≥1 Uploaded, step==1 -> step1 Completed, step2
InProgress -> notify_admins

Step2 (Validation): HR reviews ../review {Approved|Rejected+notes} per doc
      -> if Rejected notify emp + reset; when all Approved && step==2 -> ready for
proceed

Proceed gate POST /api/onboarding-proceed:
  2->3: if pending doc >0 =>400 else creates task "System Allocation" due+7, workflow 3
  3->4: requires System Allocation Completed else400; creates "Desk & ID Card" task
  4->5: sets step5 InProgress
  Initiate-setup alternative POST /api/onboarding-initiate-setup: all Approved else400
+ not exist 409 -> 2 tasks (IT Setup, ID Card)

Step5: Employee POST /api/onboarding/complete-intro (step==5 else400) -> step5
Completed, user Active if was Onboarding -> notify

Exit: workflow completed, status Active.
Failure: 400 wrong step, 404 no workflow, 413 size, 409 duplicate.
```

6.6 Offboarding 5-Step

```
HR creates tasks/exit interviews.
Workflow POST /api/offboarding-proceed {emp_id} (admin):
  sequentially steps 1..5, guard previous done else400
  per step sets stepX_done=1
  step5: completed=1 + user status Inactive + notify_admins
GET /api/offboarding-workflow shows {step_labels, done flags, completed}
```

6.7 Recruitment (ATS) Pipeline

```
HR/Admin: POST /api/jobs {title} -> Open job
          POST /api/candidates {name,email} -> Applied (6 stages)
          POST /api/interviews {candidate_id,scheduled_at} -> Scheduled
          PUT ../feedback -> Completed
          POST /api/offers {candidate_id,salary} -> Pending + candidate Offered
          POST ../accept -> Accepted + candidate Hired + now
          .../reject -> Rejected (idempotent)
          PUT /api/candidates/<id>/status {Applied..Rejected}
          POST /api/candidates/<id>/convert (must be Hired) -> creates user Pre-hire (
allow_login 0)
          + salary_structure (50/20/20 split if salary)
          + onboarding_workflow + 5 checklist Pending
          Pipeline GET /api/pipeline -> per-job counts + converted {pre_hire,onboarding,
active} + employees

Stages diagram: Applied -> Screened -> Interviewed -> Offered -> Hired -> [Onboarding
Active]
               \-> Rejected (any stage)
```

6.8 Payroll Run

```
HR/Admin: Manage salary_structures POST /api/salary-structures {emp_id,basic,hra,...}
          Manage rates PUT /api/payroll-rates (pf_rate/max, esi_rate/max_gross, pt_*,
          tds slabs)
          Preview POST .../preview to calc gross/net/TDS
          POST /api/payroll-runs {month,year} -> duplicate 409 else Draft: for each
Employee joined latest salary_structure effective<=now, calc via helpers, insert items (
transaction)
          Finalize POST .../finalize -> Finalized
          Query Items, My payslips, Payslip JSON/PDF (self/admin), Bank CSV, TDS report
          Reports poll /my-payslips, generate PDF sets payslip_generated=1
```

6.9 Expenses & Tickets (Service Workflows)

```
Expenses: Employee POST /api/expenses {cat_id,amount} -> Pending
          Manager/HR PUT .../status {Approved/Rejected} (manager-guard for those) else
Paid any-logged (gap)
          Notify via category Expenses

Tickets: Employee POST /api/tickets {queue=HR|IT, sub_category validated, subject} ->
Open -> notify_department(queue)
          Visibility: _visible_where(emp_id||assigned||category==dept) except admin sees
filtered only
          Comments POST .../comment -> Updated, Status PUT .../status {Open/In Progress/
Resolved/Closed}
          Assign PUT .../assign (admin) -> assigned_to
          Queues isolated; Super Admin sees both.
```

6.10 Holidays & Opt-in (Optional Holidays)

```
HR POST /api/holidays {name,date,National/Optional} -> dup 409 -> audit + notify Active
users by work_location
          PUT/DELETE/copy/import similarly
Opt-ins: Employee POST .../<id>/optin (only Optional, duplicate 409) -> Pending
          .../optout -> delete
          HR GET /api/holiday-optins?status -> list; approve/reject POST ->
Approved/Rejected + notify
          iCal GET /holidays/calendar.ics -> VCALENDAR per holiday (filtered by mine)
```

6.11 Shift & Calendar

```
User CRUD includes shift_start/shift_end (HH:MM or 24x7)
Shift helpers:
  shift_date(dt) => dt.date if dt >= shift_start_today else dt-1day
  shift_start_dt(date) => date at shift_start (or 00:00 if 24x7)
  shift_end_dt => shift_start with end time rolled +1day if night

Attendance semantics:
  session_date = shift_date(login_time) not calendar date
  break_date similarly
  login_hours = last_login (FIFO-LILO), not sum of sessions
  productive = shift_hours - break_minutes/60
  efficiency = productive/shift_hours *100
Calendar: month views group sessions/breaks by break_date/session_date; leaves expanded
day-by-day; holidays.
```

6.12 Notification Preferences

```
User GET/POST /api/notification-preferences: 5 cats (Onboarding,Leaves,Expenses,Tickets,
Payroll) each {in_app,email} defaults 1
add_notification checks pref before insert/email; send-email endpoint respects same.
read endpoint clears (DELETE) vs mark.
```

7. Data Model / ERD

7.1 Entity Overview (34+ tables + migrations)

```

users (EMP PK) 1--* user_sessions (session_id PK, session_date indexed by shift)
1--* breaks (break_id PK, break_date, status Active/Completed/Orphaned)
1--* break_approvals (approval_id PK, break_date, Lunch only)
1--* leave_requests (leave_id PK, year, status Pending/Approved/Rejected/
Cancelled)
1--* leave_balance (balance_id PK, emp_id+type+year unique logically)
1--* monthly_leave_grants (grant_id PK)
1--* regularization_requests (request_id PK)
1--* assets (asset_id PK, Issued/Returned)
1--* notifications (notification_id PK)
1--1 notification_preferences per category (pref_id PK, emp_id+category
UNIQUE)
1--* password_reset_tokens (token_id PK, used BIT)
1--* employee_documents / documents (documents unified: context General/
Personal/Onboarding, doc_type)
1--* dependents
1--* goals / performance_reviews / feedback_360
1--* salary_structures (struct_id PK, effective_from)
1--* payroll_items (via payroll_runs {month,year})
1--* tickets (+ ticket_comments)
1--* onboarding_tasks / onboarding_checklist / onboarding_workflow (emp PK,
5 steps)
1--* offboarding_tasks / offboarding_workflow / exit_interviews
1--* holiday_optins (emp+holiday UNIQUE)

```

7.2 Key Tables Detail

users -- hrms/schema.py:22, migrations add 15 cols (schema.py:692, migrations._migration_013)

```

emp_id VARCHAR PK, name, email, password(bcrypt), role(6), department, designation,
manager_emp_id FK->users, phone, date_of_birth, date_of_joining, address,
emergency_contact_name/phone, status(Active/Blocked/Archived/Pre-hire/Onboarding/
Inactive),
allow_login BOOL, allow_breaks BOOL, first_login TS, created_at TS,
archived_at, gender, blood_group, marital_status, nationality, pan,
bank_name, bank_account, ifsc, uan, pf_number, esi_number,
employee_type, probation_end, work_location, shift_start(HH:MM|24x7), shift_end,
candidate_id, offer_id

```

breaks / break_types / break_approvals -- schema.py:70,79,95

```

break_types(break_type PK, daily_limit 15/60/30, description)
breaks(break_id PK, emp_id FK, break_type FK, start_time TS, end_time TS, duration INT,
break_date DATE, status)
break_approvals(approval_id PK, emp_id FK, break_type FK, break_date DATE, reason,
status Pending/Approved/Rejected, approved_by FK, created_at)

```

leave_* -- schema.py:123,141,155

```

leave_requests(leave_id PK, emp_id FK, leave_type, start_date, end_date, year INT
default 0, reason, status, approved_by, created_at, updated_at)
leave_balance(balance_id PK, emp_id FK, leave_type, total_days INT, used_days INT, year
INT)
monthly_leave_grants(grant_id PK, emp_id FK, leave_type, days INT, month INT, year INT,
granted_by FK, created_at)

```

payroll_* -- schema.py:442,456,467, helpers.calc_*

```

salary_structures(struct_id PK, emp_id FK, basic/hra/allowances/deductions DECIMAL,
effective_from DATE)
payroll_runs(run_id PK, month INT, year INT, processed_at TS, status Draft/Finalized)
payroll_items(item_id PK, run_id FK, emp_id FK, gross, deductions_total, net, pf, esi,
pt, payslip_generated BOOL)
payroll_rates(rate_id PK, label, rate_type VARCHAR (pf_rate, pf_max,...tds_*), value
DECIMAL, effective_from/to, description)

```

ATS

```

job_postings(job_id PK, title, department, location, description, requirements, status
Open/Closed, created_at)
candidates(candidate_id PK, job_id FK, name, email, phone, resume_text, status Applied..
Rejected, applied_at)
interviews(interview_id PK, candidate_id FK, scheduled_at TS, interviewer FK, mode,
feedback, status)
offer_letters(offer_id PK, candidate_id FK, offered_salary DECIMAL, offer_date DATE,
status Pending/Accepted/Rejected, accepted_at, notes)

```

Onboarding/Offboarding -- see Sec. 5 FR-ONB/OFF.

Other

```

holidays(holiday_id PK, name, holiday_date DATE, year INT, type National/Optional,
location VARCHAR default All, description)
holiday_optins(optin_id PK, emp_id FK, holiday_id FK, status Pending/Approved/Rejected,
UNIQUE(emp,hol))
tickets(ticket_id PK, emp_id FK, subject, description, category(HR/IT), sub_category,
priority Medium, status Open..Closed, assigned_to FK)
ticket_comments(comment_id PK, ticket_id FK, emp_id FK, comment, created_at)
expense_categories(cat_id PK, name, description) -- 6 seed
expense_claims(claim_id PK, emp_id FK, cat_id FK, amount DECIMAL, description,
receipt_path, status Pending/Approved/Rejected/Paid, approved_by FK)
assets(... status Issued/Returned)
documents(doc_id PK, emp_id FK, name, category, file_path, file_size, uploaded_at,
context General, doc_type)
audit_log(log_id PK, emp_id, action, details, ip, created_at)
notifications(notification_id PK, emp_id FK, type, message, related_link, is_read,
created_at)
notification_preferences(pref_id PK, emp_id FK, category, in_app, email, UNIQUE(emp,
cat))
user_permissions(perm_id PK, emp_id FK, module, allowed BIT, UNIQUE(emp,module))
schema_migrations(migration_id VARCHAR PK, description, applied_at)

```

7.3 ER Diagram (text)

```

[users] 1--* [user_sessions] (session_date = shift_date)
[users] 1--* [breaks] -- belongs to [break_types]
[users] 1--* [break_approvals] --->[break_types]
[users] 1--* [leave_requests] -- checked vs [leave_balance] & [holidays]
[users] 1--* [monthly_leave_grants]
[users] 1--* [payroll_items] via [payroll_runs]
[users] 1--* [salary_structures]
[users] 1--* [tickets] --> [ticket_comments]
[users] 1--* [documents]
[users] 1--* [onboarding_workflow] 1--* [onboarding_checklist]
[users] 1--* [offboarding_workflow]
[candidates] --0..1--> [users] (candidate_id)
[job_postings] 1--* [candidates] 1--* [interviews] 1--* [offer_letters]
[holidays] 1--* [holiday_optins] *-1 [users]

```

8. API Specification

Base: session cookie auth. All login-guarded return 401 JSON if header wants JSON else redirect dashboard (decorators.py:1). Admin/perm returns 403 likewise.

Swagger at /docs/ (hrms/__init__.py:92), spec /apispec.json (filters /api/*).

8.1 Endpoint Catalog (>85 routes)

Group	Method	Path	Auth	Notes
Health	GET	/api/___health	none	db_ok
Auth	GET	/	none	redirect
	GET/POST	/login	none	limiter 20/min
	GET	/logout	opt	
	GET	/dashboard	login	admin vs user render
	POST	/api/forgot-password	none	limiter 5/min
	POST	/api/reset-password	none	limiter 5/min
	GET	/api/csrf-token	login	
	GET	/api/credentials	admin	manual check
Users	GET	/admin/users	perm users	page
	GET	/api/users	perm users	list paginated
	POST	/api/users	perm users	create
	GET/PUT	/api/users/<emp_id>	perm users	detail
	POST	/api/users/<id>/block unblock restore purge	perm/purge admin	purge admin only
	DELETE	/api/users/<id>	perm users	archive
	POST	/api/users/bulk	perm users	bulk
	GET	/api/users/meta export sessions	perm users	
	GET/PUT	/api/users/<id>/permissions	perm users	
	POST	/api/users/import + /api/v1/users/import	perm users	CSV
	GET	/admin/import-users	hr/admin	page
	GET/POST	/api/dependents + v1	login	
	DELETE	/api/dependents/<id> + v1	login	
	POST	/api/employee-documents + v1	login	
	GET	/profile	login	page
	GET/PUT	/api/profile	login	
	POST	/api/change-password	login	
Attendance	POST	/api/start-break	login	
	POST	/api/end-break/<id>	login	
	GET	/api/user-breaks	login	
	GET/POST	/api/break-approvals	login	
	POST	/api/break-approvals/<id>/approve reject	login (manager/HR check)	
	GET	/api/break-types	login	
	GET	/api/login-hours	login	
	GET	/api/user/shift-summary	login	
	GET	/api/user/calendar	login	
	GET	/api/live-monitoring	admin	
	GET	/api/break-summary disposed-breaks dashboard-stats admin/breaks	admin	
	POST	/api/admin/dispose-break/<id>	admin	
	GET/POST	/api/regularization + v1	login	

Group	Method	Path	Auth	Notes
	POST	/api/regularization/<id>/approve reject cancel + v1	login (manager/HR)	
	GET	/api/regularization/export + v1	admin	
	GET	/regularization	login	page
Leaves	GET	/leaves	login	page
	GET	/admin/leaves	hr/admin	page
	GET/POST	/api/leaves + v1	login	
	GET	/api/leaves/export + v1	admin	
	POST	/api/leaves/<id>/approve reject cancel + v1	login (manager/HR)	
	GET	/api/leave-balance + v1	login	
	GET	/api/leave-grants + v1	hr/admin	
	POST	/api/leave-grants + v1	hr/admin	
Payroll	GET	/admin/payroll /admin/settings/payroll-rates /admin/salary-structures	hr/admin or admin	pages
	GET/POST	/api/salary-structures + v1	hr/admin	
	POST	/api/salary-structures/preview	hr/admin	
	GET/PUT	/api/payroll-rates	admin	
	GET	/api/review-cycle-progress	login	
	GET/POST	/api/payroll-runs + v1	hr/admin	
	POST	/api/payroll-runs/<id>/finalize	hr/admin	
	GET	/api/payroll-runs/<id>/items	hr/admin	
	GET	/api/payslip/<run>/<emp> + v1	login(self/admin)	JSON
	GET	/api/my-payslips + v1	login	
	GET	/api/payroll-runs/<id>/payslip-pdf/<emp> + v1	self/admin	PDF
	GET	/api/payroll-runs/<id>/bank-file + v1	hr/admin	CSV
	GET	/api/payroll-runs/<id>/tds-report + v1	hr/admin	
Expenses	GET	/admin/expenses	hr/admin	page
	GET	/expenses	login	page
	GET	/api/expense-categories + v1	login	
	GET/POST	/api/expenses + v1	login	
	PUT	/api/expenses/<id>/status + v1	login(manager/HR)	
Tickets	GET	/admin/tickets	dept HR/IT	page
	GET	/tickets	login	page
	GET/POST	/api/tickets + v1	login	
	GET	/api/tickets/<id> + v1	login	
	POST	/api/tickets/<id>/comment + v1	login	
	PUT	/api/tickets/<id>/status + v1	login	
	PUT	/api/tickets/<id>/assign + v1	admin	

Group	Method	Path	Auth	Notes
Documents	GET	/admin/documents	hr/admin	page
	GET	/documents	login	page
	GET	/api/documents +v1	login	
	POST	/api/upload +v1	login	multipart
	GET	/api/documents/<id>/download +v1	login(self/admin)	
	DELETE	/api/documents/<id> +v1	login	
Onboarding	GET	/onboarding	login	page
	GET/POST	/api/onboarding-tasks +v1	login/post any, complete admin	
	POST	/api/onboarding-tasks/<id>/complete progress +v1	admin	
	POST	/api/onboarding-proceed	admin	
	DELETE	/api/onboarding-tasks/<id> +v1	admin	
	GET	/api/onboarding-tasks/export +v1	admin	
	GET/POST	/api/onboarding-checklist +v1	GET login, POST admin	
	POST	/api/onboarding-checklist/<id>/upload file review +v1	login/admin per op	
	DELETE	/api/onboarding-checklist/<id> +v1	admin	
	POST	/api/onboarding-initial-setup +v1	admin	
	POST	/api/onboarding-checklist/submit onboarding/complete-intro onboarding-status	login/admin	
Offboarding	GET	/offboarding	login	page
	GET/POST	/api/offboarding-tasks +v1	login	
	POST	/api/offboarding-tasks/<id>/complete +v1	admin	
	GET/POST	/api/exit-interviews +v1	admin	
	GET	/api/offboarding-workflow	login	
	POST	/api/offboarding-proceed	admin	
Performance	GET	/admin/goals	hr/admin	page
	GET	/admin/reviews	hr/admin	redirect
	GET	/goals	login	page
	GET/POST	/api/goals +v1	login	
	PUT	/api/goals/<id>/rate +v1	admin	
	PUT	/api/goals/<id> +v1	login	
	GET/POST	/api/performance-reviews +v1	hr/admin	
	PUT	/api/performance-reviews/<id>/submit +v1	login	
	GET/POST	/api/feedback-360 +v1	login	
Holidays	GET	/holidays /admin/holidays	login/perm	pages

Group	Method	Path	Auth	Notes
	GET/POST	/api/holidays +v1	login/perm	
	PUT/DELETE	/api/holidays/<id>	perm	
	POST	/api/holidays/copy import	perm	
	GET	/api/holidays/export calendar.ics	perm/login	
	POST	/api/holidays/<id>/optin optout	login	
	GET	/api/holiday-optins	perm	
	POST	/api/holiday-optins/<id>/approve reject	perm	
ATS	GET	/admin/jobs candidates offers pipeline	hr/admin	pages
	GET	/api/pipeline +v1	hr/admin	
	GET/POST	/api/jobs +v1	admin	
	POST	/api/jobs/<id>/close +v1	admin	
	GET/POST	/api/candidates +v1	hr/admin	
	POST	/api/candidates/<id>/convert +v1	hr/admin	
	PUT	/api/candidates/<id>/status +v1	hr/admin	
	GET/POST	/api/interviews +v1	hr/admin	
	PUT	/api/interviews/<id>/feedback +v1	hr/admin	
	GET/POST	/api/offers +v1	hr/admin	
	POST	/api/offers/<id>/reject accept +v1	hr/admin	
Analytics	GET	/admin/analytics	hr/admin	page
	GET	/api/analytics/headcount leave-trends attrition-risk expense-summary performance-summary (+v1)	admin/hr/admin per route	filtered
Reports	GET	/admin/reports /reports	hr/admin/login	pages
	GET	/api/reports	login	JSON summary
	GET	/api/reports/export +v1	login	Excel
	GET	/api/reports/departments-summary	hr/admin	
Audit	GET	/admin/audit	hr/admin	page
	GET	/api/audit-log +v1	admin	
	GET	/api/audit-modules	admin	
Notifications	GET	/api/notifications +v1	login	
	POST	/api/notifications/read +v1	login	
	POST	/api/send-notification-email +v1	admin	
	GET/POST	/api/notification-preferences +v1	login	
Assets	GET	/admin/assets	hr/admin	page
	GET	/api/my-assets +v1	login	
	GET/POST	/api/assets +v1	admin	
	POST	/api/assets/<id>/return +v1	admin	

Detailed schemas per Swagger `/apispec.json`; error envelope `{error: string}` with HTTP 400/401/403/404/409/429/500.

8.2 Representative JSON

POST `/api/leaves`

```
Request: {"leave_type": "Casual", "start_date": "2026-05-20", "end_date": "2026-05-21",  
"reason": "Personal"}  
Success 201: {"message": "Leave application submitted", "leave_id": 12345}  
Errors: 400 insufficient balance, 409 overlapping
```

GET `/api/user/shift-summary`

```
{"date": "2026-05-13", "shift_start": "09:00", "shift_end": "18:00", "first_login": "09:12:04",  
"last_logout": null,  
"shift_hours": 4.5, "productive_hours": 4.0, "efficiency": 88.9, "session_count": 1,  
"break_count": 2, "total_break_minutes": 30}
```

POST `/api/start-break`

```
Request: {"break_type": "Lunch"}  
Success 201: {"message": "Break started", "break_id": 999, "break_type": "Lunch"}  
Error 403: {"error": "Lunch break requires manager approval"}  
Error 400: {"error": "Daily limit of 60 min reached for Lunch"}
```

9. UI / UX Requirements

9.1 Pages (35 templates, templates/*.html)

Route	Template	Roles visible	Key UI
/login	login.html	public	form emp_id/password, forgot link
/dashboard	admin_dashboard.html	Admin/HR	live stats cards (total/logged-in/on-break/blocked/pending leaves), polls /api/dashboard-stats
/dashboard	user_dashboard.html	Employee	shift hours, breaks, calendar widget
/profile	profile.html	auth	23 fields + perms
/admin/users	admin_users.html	perm users	table, CRUD modal, bulk, import, shift columns
/admin/import-users	import_users.html	hr/admin	CSV upload
/holidays	holidays.html	auth	calendar, opt-in toggles, iCal link
/leaves	leaves.html	auth	apply modal, balance chips, pending approvals
/admin/leaves	admin_leaves.html	hr/admin	filters month/year, approvals
leaves balance	via leaves page	auth	chips Casual/Sick/Annual remaining
/regularization	regularization.html	auth	table status, approve/reject for managers
break	in dashboard	auth	start/end buttons, checkActiveBreak() + self-heal
/admin/assets	assets.html	hr/admin	issue/return
/expenses	expenses.html	auth	submit, manager pending tab
/admin/expenses	admin_expenses.html	hr/admin	approvals
/tickets	tickets.html	auth	queue submit HR/IT, comments
/admin/tickets	admin_tickets.html	HR/IT/Admin	queue filter, assignment
/documents /admin/documents	documents.html admin_documents.html	auth / hr/admin	upload, download, context badge
/onboarding	onboarding.html	auth	5-step wizard, doc upload 250KB/Photo1MB, proceed
/offboarding	offboarding.html	auth	5-step, exit interviews
/admin/jobs	jobs.html	hr/admin	job list, close
/admin/candidates	candidates.html	hr/admin	list, convert
/admin/offers	offers.html	hr/admin	offer accept/reject
/admin/pipeline	pipeline.html	hr/admin	kanban stages + converted employees with workflow steps
/goals /admin/goals	my_goals.html goals.html	auth / hr/admin	goals CRUD, rating
reviews/feedback_360	reviews.html	hr/admin/auth	review submit
/admin/payroll	payroll.html	hr/admin	salary structures, runs, bank/TDS
/admin/settings/payroll-rates	admin_payroll_rates.html	admin	rates editor
/admin/salary-structures	salary.html	hr/admin	structures list
/admin/analytics	analytics.html	hr/admin	charts headcount/leave/attrition/expense/perf
/admin/reports /reports	reports.html	hr/admin / auth self	range/aggregate tables, Excel export
/admin/audit	admin_audit.html	hr/admin	log table + modules filter

9.2 Design System

- Inter font, slate palette (#0F172A primary), soft shadows, rounded cards (_shared_css.html, _base_start.html).
- Status chips color-coded: Active/Completed/Pending/Approved/Rejected/Cancelled/Orphaned.
- Toast non-blocking, skeleton loaders, real-time polling breaks/notifications/stats.
- Navbar: role-gated per AGENTS (Sec. 2.3).
- Calendar: interactive month, merges sessions(badge hours), breaks(minutes), leaves(color), holidays.
- Responsive Bootstrap 5, ARIA/semantic HTML.

9.3 Accessibility & UX Laws

- Focus indicators, ARIA labels, semantic tables.
- Polled updates avoid stale break buttons (AGENTS fix: always show No active break when idle).
- File validation immediate (extension/size before upload) + server re-check.

10. Non-Functional Requirements

Category	Requirement	Metric	Source
Performance	Page load <2s cold, API p95 <300ms on DuckDB file	Lighthouse, pytest timing	--
Availability	99% (single node), scheduler survives restart via <code>atexit + .secret_key</code> persistence. Multi-worker requires external scheduler.	--	<code>__init__.py:209</code>
Scalability	Supports 5k users, 100 concurrent requests (DuckDB limit). Future: migrates to Postgres without API change.	load test (playwright 11-16 tests ports 8787/8788)	<code>tests/test_playwright*.py</code>
Security	OWASP: bcrypt, rate-limit (20/min login, 5/min pwd), HSTS prod, HttpOnly/Lax, X-Frame DENY, audit, validation	ASVS L1	Sec. 11
Usability	Mobile friendly, WCAG AA (contrast, keyboard), error messages actionable (400/409 detail)	a11y test	--
Reliability	Orphan break auto-resolve 12h; expired tokens purged hourly; transactions on payroll.	--	--
Maintainability	15 migrations versioned; <code>init_db</code> idempotent; 229-258 tests across 6 suites (README, AGENTS).	coverage	--
Portability	Docker single <code>docker compose up -d (docker-compose.yml)</code> , Render.yaml deploy. Env-driven.	--	--
Observability	Sentry optional (<code>SENTRY_DSN</code>), structured logs <code>hrms</code> logger, health <code>/api/__health</code> .	--	<code>app.py:21</code>
Data Integrity	FK via DuckDB (logical), <code>gen_id <2^31</code> random PKs, dedup via <code>dict.fromkeys</code> in imports.	--	--
Backup	DuckDB file snapshot + <code>hrms.duckdb.wal</code> (present in repo); recommend S3 copy daily if prod.	--	--

11. Security Requirements

ID	Requirement
SEC-01	Passwords bcrypt-hashed (<code>helpers.hash/check_password</code>), min6, never logged.
SEC-02	RBAC: <code>@login_required</code> , <code>@admin_required</code> , <code>@permission_required(module)</code> (<code>decorators.py:1</code>), <code>@hr_or_admin_required</code> , <code>@department_required</code> , <code>@manager_or_admin_required</code> (ownership via <code>manager_emp_id</code>). API vs page 403/401 divergence.
SEC-03	Session fixation: clear on login (<code>session.clear()</code>), <code>HttpOnly/Secure/Lax/8h</code> , <code>ProxyFix</code> .
SEC-04	CSRF token endpoint + potential hidden-field enforcement (gap: evaluate header <code>X-CSRF-Token</code> on mutating <code>/api/*</code> -- recommend add).
SEC-05	Rate limiting <code>Flask-Limiter</code> memory (disabled in <code>test</code>), per-route.
SEC-06	Security headers: <code>X-Content-Type-Options nosniff</code> , <code>X-Frame DENY</code> , <code>X-XSS 1;mode=block</code> , <code>Referrer-Policy strict-origin-when-cross-origin</code> , <code>HSTS prod (__init__.py:191)</code> .
SEC-07	Input validation: regex <code>EMP\d+</code> , email contains <code>@</code> , role in <code>ROLES</code> , date <code>parse_date</code> strict, file ext/size, int ranges (days 1-365 etc).
SEC-08	Authorization gaps to remediate: <code>DELETE /api/documents/<id></code> should check owner/admin (currently any auth) (<code>documents.py</code>); <code>expense status Paid</code> bypasses manager (review); <code>performance Reviews submit</code> missing role check; <code>expenses create emp_id</code> spoof (<code>expenses.py:POST emp_id</code> fallback) -- enforce <code>session.emp_id</code> .
SEC-09	Audit all sensitive mutations (<code>helpers.audit_log</code> with IP) -- schema <code>audit_log</code> retained.
SEC-10	Uploads sanitized <code>file_name</code> with ts prefix, stored outside web root enumeration, MIME map on download, size caps.

12. Reporting & Analytics

- **Ops reports:** `GET /api/reports` aggregates per user shift; export 3-sheet Excel (Summary/Break Details/Session Details) with styled headers (`reports.py`). Department summary grouped.
- **Admin analytics** (filters `department`, `date_from/to`): headcount, leave-trends (monthly), attrition-risk heuristic (leave/reg/early-break/attendance/rating), expense-summary by category, performance-summary avg/by-dept (`analytics.py`).
- **Coverage tests:** 34 `api_coverage`, 24 workflows, 16 e2e browser per AGENTS (separate DB env vars, must not combine suites).

13. Deployment & DevOps

Area	Detail
Local	<code>python -m venv .venv && pip -r requirements.txt && python app.py</code> on 5000 (PORT env).
Docker	<code>docker build -t hrms . && docker run -p5000:5000 -e SECRET_KEY=\$(openssl rand -hex 32) hrms</code>
Compose	<code>docker compose up -d</code>
Render	<code>render.yaml</code> one-click, <code>SECRET_KEY</code> via dashboard
Env	<code>.env.example</code> , <code>.env.production.example</code> , actual <code>.env</code> ; <code>DB_FILE</code> <code>hrms.duckdb</code> , <code>UPLOAD_FOLDER</code> <code>uploads</code> , SMTP/Sentry optional
CI	Not present -- recommend GitHub Actions running <code>pytest</code> suites separately (AGENTS note: separate DB env prevents 403 flake). Add <code>ruff</code> (pyproject target <code>py313</code> , line 120).
Scheduler caveat	<code>APScheduler</code> in-process; if <code>gunicorn workers>1</code> duplicates -- migrate to single cron or Redis lock.

14. Traceability Matrix (excerpt)

FR	Blueprint Code	Template	Test
FR-AUTH-01	auth.py:POST /login	login.html	test_app.py login_*
FR-ATT-02	attendance.py:start_break	user_dashboard	test_api_coverage break_limit
FR-LEA-04	leaves.py:approve_leave	admin_leaves.html	test_workflows leave_flow
FR-PAY-05	payroll.py:payroll_runs_api	payroll.html	test_api_coverage payroll
FR-ONB-04	onboarding.py:onboarding-checklist upload	onboarding.html	test_app onboarding
FR-AST-01	assets.py:assets_api	assets.html	test_workflows asset
FR-NOT-01	notifications.py:notifications_api	navbar bell	test_app notifications
FR-RPT-01	reports.py:reports_api	reports.html	test_workflows reports isolation

Full matrix in `tests/` -- 6 suites, 229-258 cases; separate DB file per suite needed (AGENTS).

15. Glossary

(See Sec. 1.3 plus) - **Shift Date:** Logical day keyed by `shift_start`; enables night-shift correctness vs calendar date. - **Orphaned Break:** Active >12h auto-closed by scheduler. - **Self-service Report:** Employee can only view own rows; param ignore. - **Pre-hire:** Candidate-converted user `allow_login 0` awaiting onboarding.

16. Appendices

16.1 Seed Data

- Users EMP001-006 roles defined Sec. 2.3, pwd `pass123`
- Break types Tea 15, Lunch 60 (approval), Personal 30
- Leave Casual12/Sick10/Annual20 per year; Expense cats 6; Holidays 5 New Year/Republic/Independence/Diwali/Christmas; Payroll rates seed defaults

16.2 Role-Permission Matrix (`code truth helpers.ROLE_DEFAULT_PERMISSIONS`)

Module (21)	Super Admin	Admin	HR	IT	Team Leader	Employee
users, jobs, payroll, salary_structures, documents*	v	v	(candidates only)	-- (docs v)	--	--
leaves, regularization, breaks, holidays	v	v	v	--	leaves/reg only	self*
expenses, onboarding, offboarding, audit, analytics, reports	v	v	v	-- (reports v)	-- (reports v, perf v)	-- (reports self)
tickets, assets	v	v	-- (tickets via HR queue)	v	--	own
performance	v	v	--	--	v	own goals
import_users, payroll_rates	v	v	--	--	--	--
*Self means own records via <code>emp_id=me</code> ; admin always sees all. Overrides in <code>user_permissions</code> can flip any.						

16.3 Key Decisions vs Open-Source HRMS

Feature	OrangeHRM	Sentrifugo	IceHRM	This HRMS
Leave approval	Manager -> HR -> Admin	Manager/HR	HR	Manager/HR (same, with holiday deduction -- improvement)
Attendance	Punch in/out sum	Corrections	Shifts	Shift-aware date + FIFO-LILO login hours + auto-orphan (more accurate for night shifts)
Break governance	Not modeled	Not modeled	Not modeled	Daily limit + Lunch approval + live monitoring (unique value add)
Onboarding	Checklist	5-step wizard	Docs only	5-step checklist + tasks + size-gated upload + sequential proceed (hybrid best-of)
Recruitment	Full ATS	Not full	Jobs only	Full pipeline with conversion to onboarding workflow (Orange parity)
Payroll	Not in CE	Not	Rates + structures	Rates-driven calc + TDS + payslip PDF + bank file (IceHRM+)
Notifications	Email	Email	In-app	Both, per-category prefs (improvement)
Analytics	Dash only	Reports	Reports	Headcount/leave/attrition-risk/expenses/perf + reports dept-summary (Sentrifugo parity + heuristic attrition)

16.4 Future Roadmap (from gaps & modern HRMS trends)

- 1. External DB (PostgreSQL) + uploads to S3/minio.
- 2. Enforce CSRF header on POST /api/*, fix auth gaps noted SEC-08.
- 3. Unified frontend framework migration (React/Next per UI-ux-pro-max skill) -- keep Jinja initially.
- 4. Biometric/SSO (SAML, OIDC), mobile PWA, push notifications.
- 5. Role Team Leader expansion: team dashboard & bulk approve.
- 6. External payroll gateway, Elasticsearch audit search, retention policy.
- 7. Dedicated cron/migrator (APScheduler -> separate container).
- 8. Comprehensive OpenAPI example responses + contract tests (keep flasgger).

16.5 Document History

Version	Date	Change
0.1 draft	2026-05-13	Initial generation via codebase task (explore agent + manual read)
1.0	2026-05-13	Baseline -- aligned to current app.py/schema.py + migrations 001-015

Maintainer note: Regenerate this SRS after any Blueprint or migration change: re-run explore agent over `hrms/*.py` and `templates/*.html`, diff FRs, update traceability and version.

SIGN-OFF

ROLE	NAME	SIGNATURE	DATE
Product Owner			
Engineering Lead			

HR Stakeholder			
QA Lead			

Regenerate this SRS after any blueprint or migration change: re-run explore over **hrms/*.py** and **templates/*.html**, diff FRs, update traceability and version.
Store generated PDF as **docs/SRS.pdf** alongside source **docs/SRS.md**.